

Mapeo de Preguntas a Requisitos Normativos y Marcos

NIST CSF 2.0, ENS, ISO/IEC 27001, NIS2/DORA (nivel alto)

Nota: Este mapeo es orientativo y de alto nivel. No sustituye a un análisis jurídico detallado ni a un mapeo fino control a control.

ID Pregunta	Función CSF 2.0	Tema principal	Referencias NIST CSF 2.0 (ejemplos)	Normativa/ marcos relacionados (alto nivel)
P-GV-01	GV	Estrategia formal de ciberseguridad	GV.OV, GV.PO	ENS (organización e implantación); ISO 27001 cl. 5 (liderazgo); NIS2 (estrategia de ciberseguridad)
P-GV-02	GV	Objetivos con métricas (KPIs/KRIs)	GV.RR, GV.RM	ISO 27001 cl. 6 (planificación); COSO ERM; ENS (gestión de riesgos)
P-GV-03	GV	Revisión periódica de estrategia	GV.OV, GV.RM	ISO 27001 cl. 9 (evaluación del desempeño); ENS (revisión y mejora)
P-GV-04	GV	Apetito de riesgo formal	GV.RM	COSO ERM; NIS2 (gestión del riesgo); ENS (análisis y gestión de riesgos)
P-GV-05	GV	Uso práctico del apetito de riesgo	GV.RM	ISO 27005; MARCOS ERM corporativos
P-GV-06	GV	Existencia de CISO/responsable	GV.OV	ENS (figuras de seguridad); ISO 27001 cl. 5; NIS2 (responsables)
P-GV-07	GV	Reporting a alta dirección	GV.OV, GV.RR	ISO 27001 cl. 5, 9; ENS (responsabilidades y funciones)
P-GV-08	GV	Indicadores alineados a marcos	GV.RR	ISO 27001; Balanced Scorecard de SI; frameworks GRC

ID Pregunta	Función CSF 2.0	Tema principal	Referencias NIST CSF 2.0	Normativa/ marcos relacionados
P-ID-01	ID.AM	Inventario de activos	ID.AM	ENS (inventario de activos); ISO 27001 A.5 & A.8
P-ID-02	ID.AM	Cobertura automática de inventario	ID.AM	Buenas prácticas de CMDB; ITIL; ISO 27001 A.5, A.8
P-ID-03	ID.IM / ID.AM	Clasificación de datos	ID.IM	RGPD (clasificación de datos personales); ENS; ISO 27001 A.5
P-ID-04	ID.IM	Propietarios de datos	ID.IM	ISO 27001 (propietarios de activos); ENS; RGPD (responsables)
P-ID-05	ID.RA	Metodología de riesgo	ID.RA	ISO 27005; ENS (gestión de riesgos)
P-ID-06	ID.RA	Periodicidad de análisis de riesgo	ID.RA	ENS; ISO 27001 cl. 6, 8; NIS2 (evaluación periódica)
P-ID-07	ID.RA	Registro de riesgos ciber	ID.RA	COSO ERM; ISO 27001; ENS

ID Pregunta	Función CSF 2.0	Tema principal	Referencias NIST CSF 2.0	Normativa/ marcos relacionados
P-PR-01	PR.AA	MFA en cuentas críticas	PR.AA	ENS (control de acceso); ISO 27001 A.5, A.8; NIS2
P-PR-02	PR.AA	Gestión ciclo de vida de identidades	PR.AA	ISO 27001 A.5; ENS (control de acceso)
P-PR-03	PR.AT	Programa de concienciación	PR.AT	ENS (formación); ISO 27001 A.6
P-PR-04	PR.AT	Simulaciones de phishing	PR.AT	Buenas prácticas formación; ISO 27001 A.6
P-PR-05	PR.DS	Protección de datos sensibles	PR.DS	RGPD; ENS (protección de la información); ISO 27001 A.5, A.8
P-PR-06	PR.PT	Gestión de parches y actualizaciones	PR.PT	ENS; ISO 27001 A.8 (seguridad de operaciones)

ID Pregunta	Función CSF 2.0	Tema principal	Referencias NIST CSF 2.0	Normativa/ marcos relacionados
P-DE-01	DE.MON	Monitorización de activos críticos	DE.CM, DE.MON	ENS (registro de actividad, detección de intrusiones); ISO 27001 A.8
P-DE-02	DE.MON	Inteligencia de amenazas	DE.CM	Buenas prácticas de Threat Intel; NIS2 (intercambio de info)
P-DE-03	DE.MON	Medición de MTTD	DE.CM	Métricas operativas; ISO 27004

ID Pregunta	Función CSF 2.0	Tema principal	Referencias NIST CSF 2.0	Normativa/ marcos relacionados
P-RS-01	RS.PO, RS.CO	Plan de respuesta a incidentes	RS.PO, RS.CO	ENS (gestión de incidentes); ISO 27035; NIS2 (gestión de incidentes)
P-RS-02	RS.IM	Ejercicios de respuesta	RS.IM	ENS; ISO 27035; marcos de ejercicios nacionales
P-RS-03	RS.AN	Medición tiempo de contención	RS.AN	Métricas incidentes; ISO 27004
P-RS-04	RS.CO	Comunicación a autoridades	RS.CO	RGPD (notificación de brechas); NIS/NIS2; ENS

ID Pregunta	Función CSF 2.0	Tema principal	Referencias NIST CSF 2.0	Normativa/ marcos relacionados
P-RC-01	RC.RP	Definición de RTO/RPO	RC.RP	ISO 22301 (continuidad); ENS (continuidad); DORA (resiliencia operativa)
P-RC-02	RC.IM	Pruebas de continuidad y DR	RC.IM	ISO 22301; ENS; marcos sectoriales
P-RC-03	RC.RP, RC.IM	Cumplimiento de RTO en ejercicios	RC.RP, RC.IM	ISO 22301; métricas de continuidad

ID Pregunta	Función CSF 2.0	Tema principal	Referencias NIST CSF 2.0	Normativa/ marcos relacionados
P-SC-01	GV.SC	Inventario y clasificación de proveedores	GV.SC	NIS2 (gestión de proveedores); ENS; buenas prácticas SCRM
P-SC-02	GV.SC	Cláusulas de ciber en contratos	GV.SC	NIS2; DORA; ENS; ISO 27036
P-SC-03	GV.SC	Evaluación periódica de proveedores	GV.SC	NIS2; DORA; ISO 27036

ID Pregunta	Función CSF 2.0	Tema principal	Referencias NIST CSF 2.0	Normativa/ marcos relacionados
P-ME-01	GV.RR	Cuadro de mando de ciberseguridad	GV.RR	ISO 27004 (medición); marcos GRC
P-ME-02	GV.RM	Índices de madurez	GV.RM	NIST CSF (tiers de madurez); modelos CMMI; ENS niveles
P-ME-03	GV.RR, GV.RM	Evaluación de ROI de ciberseguridad	GV.RM, GV.RR	Prácticas de ERM y análisis coste-beneficio; guías sectoriales

Este mapeo puede ampliarse con referencias específicas (artículos, controles, secciones) según la necesidad del proyecto o del regulador.